



MINOR PROJECT - 1

# CYBERSECURITY RISK ASSESSMENT FRAMEWORK FOR SMALL BUSINESSES

A Model for Evaluating Cybersecurity Risks in SMEs  
and Proposing Effective Mitigation Strategies

---

Internship Completion Project | Naviotech Solution Pvt Ltd

Domain: Cybersecurity • Submitted: July 2026

# CERTIFICATE OF PROJECT COMPLETION

*Naviotech Solution Pvt Ltd*

---

This is to certify that the Minor Project – 1 titled “Cybersecurity Risk Assessment Framework for Small Businesses” has been carried out as part of the Internship Completion Program at Naviotech Solution Pvt Ltd. The project presents an original model for evaluating cybersecurity risk exposure in small and medium enterprises (SMEs) and proposes practical, cost-effective mitigation strategies to strengthen their security posture.

The work embodies a systematic study of prevalent cyber threats, the design of a structured risk-assessment methodology aligned with the NIST Cybersecurity Framework, the development of a quantitative risk-scoring metric, and validation of the proposed model through representative case studies.

**Project Title:** Cybersecurity Risk Assessment Framework for Small Businesses

**Project Category:** Minor Project – 1

**Organization:** Naviotech Solution Pvt Ltd

**Domain:** Cybersecurity / Information Security Risk Management

**Prepared By:** Kumari Sneha

**Submission Date:** July 2026

---

Kumari Sneha  
Intern / Project Author

---

[Faculty / Mentor Name]  
Project Mentor / Supervisor

# TABLE OF CONTENTS

|                                                     |           |
|-----------------------------------------------------|-----------|
| <b>Executive Summary.....</b>                       | <b>6</b>  |
| <b>1. Introduction .....</b>                        | <b>7</b>  |
| 1.1 Background .....                                | 7         |
| 1.2 Problem Statement .....                         | 7         |
| 1.3 Project Objectives .....                        | 7         |
| 1.4 Scope of the Project .....                      | 7         |
| 1.5 Methodology Overview .....                      | 8         |
| <b>2. Common Cybersecurity Risks in SMEs .....</b>  | <b>9</b>  |
| 2.1 Threat Landscape Overview .....                 | 9         |
| 2.2 Description of Key Risk Categories .....        | 10        |
| 2.3 Comparative Risk Table .....                    | 11        |
| 2.4 Why SMEs Are Disproportionately Affected .....  | 11        |
| <b>3. Cybersecurity Risk Assessment Model.....</b>  | <b>12</b> |
| 3.1 Adopting the NIST Cybersecurity Framework ..... | 12        |
| 3.2 Proposed Risk Assessment Model.....             | 13        |
| <b>4. Risk Evaluation Metric .....</b>              | <b>15</b> |
| 4.1 Likelihood Rating Scale .....                   | 15        |
| 4.2 Impact Rating Scale .....                       | 15        |
| 4.3 Risk Evaluation Matrix.....                     | 16        |
| 4.4 Risk Priority Bands and Response Actions.....   | 16        |
| <b>5. Risk Mitigation Strategies .....</b>          | <b>17</b> |
| 5.1 Defense-in-Depth Architecture .....             | 17        |
| 5.2 Threats Mapped to Recommended Controls .....    | 17        |
| 5.3 Indicative Cost vs Risk Reduction .....         | 18        |
| 5.4 Prioritisation Guidance.....                    | 18        |
| <b>6. Model Validation — Case Studies.....</b>      | <b>19</b> |
| 6.1 Case Study Profiles .....                       | 19        |
| 6.2 Case Study A — Retail SME .....                 | 19        |
| 6.3 Case Study B — Fintech SME.....                 | 19        |
| 6.4 Case Study C — Healthcare SME .....             | 20        |
| 6.5 Consolidated Validation Results.....            | 20        |
| <b>7. Findings and Best Practices .....</b>         | <b>22</b> |
| 7.1 Key Findings.....                               | 22        |
| 7.2 SME Cybersecurity Best-Practice Checklist ..... | 22        |
| <b>8. Conclusion and Future Scope .....</b>         | <b>23</b> |
| 8.1 Conclusion .....                                | 23        |
| 8.2 Limitations .....                               | 23        |
| 8.3 Future Scope .....                              | 23        |

|                                                    |    |
|----------------------------------------------------|----|
| References.....                                    | 24 |
| Appendix A — Rapid Risk Assessment Checklist ..... | 25 |

## LIST OF FIGURES

- Figure 2.1** Most Common Cybersecurity Threats Facing SMEs
- Figure 2.2** Distribution of Reported Security Incidents by Category
- Figure 3.1** NIST Cybersecurity Framework — Five Core Functions
- Figure 3.2** Proposed Cybersecurity Risk Assessment Model (7-Stage Process)
- Figure 4.1** Risk Evaluation Matrix (Likelihood × Impact)
- Figure 4.2** Risk Score Formula
- Figure 5.1** Defense-in-Depth: Layered Security Architecture for SMEs
- Figure 6.1** NIST CSF Maturity Score — Before vs After Mitigation
- Figure 6.2** Aggregate Risk Score Reduction Across Case Studies

## LIST OF TABLES

- Table 2.1** Common Cybersecurity Risks in SMEs and Their Characteristics
- Table 4.1** Likelihood Rating Scale
- Table 4.2** Impact Rating Scale
- Table 4.3** Risk Priority Bands and Response Actions
- Table 5.1** Threats Mapped to Recommended Mitigation Controls
- Table 5.2** Estimated Cost vs Risk Reduction of Key Controls
- Table 6.1** Case Study Profiles
- Table 6.2** Case Study A — Risk Register (Sample)
- Table 6.3** Consolidated Validation Results
- Table 7.1** SME Cybersecurity Best-Practice Checklist

## Executive Summary

---

Small and medium enterprises (SMEs) form the backbone of the global economy, yet they remain the most under-protected segment when it comes to cybersecurity. Limited budgets, absence of dedicated IT security staff, and low risk awareness make SMEs an attractive target for cybercriminals. This project, undertaken as part of the Minor Project – 1 internship deliverable at Naviotech Solution Pvt Ltd, develops a structured, practical, and low-cost Cybersecurity Risk Assessment Framework tailored specifically to the operating constraints of SMEs.

The project begins by researching the most common cybersecurity risks affecting SMEs — phishing, ransomware, insider threats, weak credential management, unpatched software, cloud misconfiguration, and IoT/endpoint vulnerabilities. Building on this threat landscape, a risk assessment model is developed that aligns with the internationally recognised NIST Cybersecurity Framework (Identify, Protect, Detect, Respond, Recover), adapted into a simplified seven-stage process suitable for organisations with limited technical resources.

A quantitative risk evaluation metric — a 5×5 Likelihood × Impact matrix — is proposed to rank identified threats by severity, allowing SMEs to prioritise remediation efforts where they matter most. Corresponding mitigation strategies (firewalls, multi-factor authentication, employee security-awareness training, endpoint protection, encrypted backups, and incident response planning) are mapped against each threat category, together with indicative cost-versus-effectiveness guidance.

The model was validated through three representative case studies — a retail SME, a fintech SME, and a healthcare SME — each of which was assessed before and after the proposed controls were conceptually applied. Across all three cases, the aggregate risk score fell by 58–63%, and the composite NIST CSF maturity score improved markedly across all five core functions, demonstrating the practical value of the framework.

The report concludes with a consolidated set of best practices and a lightweight cybersecurity checklist that SMEs can adopt without significant capital investment. The framework demonstrates that meaningful, measurable improvement in cybersecurity posture is achievable for resource-constrained organisations through a disciplined, risk-based, and continuously monitored approach.

# 1. Introduction

---

## 1.1 Background

Cybersecurity has evolved from a purely technical concern into a fundamental business risk. While large enterprises typically maintain dedicated security operations centres, threat intelligence teams, and significant security budgets, small and medium enterprises (SMEs) rarely possess these resources. Yet SMEs are not exempt from the threat landscape — in fact, industry reports consistently show that a large majority of cyberattacks target smaller organisations precisely because they are perceived as easier, lower-risk targets for attackers.

SMEs increasingly rely on digital infrastructure — cloud services, e-commerce platforms, remote work tools, and connected devices — to remain competitive. This digital dependence, combined with constrained security budgets and limited in-house expertise, creates a widening gap between the threats SMEs face and their capacity to defend against them. A single successful ransomware attack, data breach, or business email compromise can be financially catastrophic and, in many documented cases, has led to permanent business closure.

## 1.2 Problem Statement

Most existing cybersecurity risk frameworks (such as ISO/IEC 27001, NIST SP 800-30, or COBIT) are designed with large enterprises in mind — they assume dedicated compliance teams, formal audit cycles, and substantial budgets. SMEs need a simplified, practical, and low-cost approach that still draws on the rigour of established frameworks but can realistically be implemented by a small IT team or even a single System Administrator managing multiple responsibilities.

There is, therefore, a clear need for a lightweight cybersecurity risk assessment model that (a) helps SMEs systematically identify and evaluate the risks most relevant to them, (b) prioritises those risks using an objective and repeatable scoring method, and (c) recommends proportionate, budget-conscious mitigation strategies.

## 1.3 Project Objectives

- To research and document the most common cybersecurity risks affecting small and medium enterprises.
- To develop a structured risk assessment model, informed by the NIST Cybersecurity Framework, suitable for SME adoption.
- To design a quantitative risk evaluation metric capable of ranking threats by severity and business impact.
- To propose practical, cost-effective mitigation strategies mapped against each identified risk category.
- To validate the proposed model through representative case studies across different SME sectors.
- To document findings and compile a set of actionable best practices for SME cybersecurity.

## 1.4 Scope of the Project

The framework developed in this project is intended for SMEs typically employing between 10 and 250 staff, operating with limited or no dedicated cybersecurity personnel. The scope covers organisational,

technical, and human-factor risks, and focuses on preventive and detective controls rather than advanced enterprise-grade solutions such as security information and event management (SIEM) platforms, given their cost and complexity for smaller organisations. The model is sector-agnostic but has been validated using case studies from the retail, fintech, and healthcare sectors to test its applicability across different risk profiles.

## 1.5 Methodology Overview

The project follows a six-step methodology, illustrated in Figure 3.2 of Chapter 3: asset identification, threat identification, vulnerability assessment, risk evaluation, mitigation planning, and implementation — supported by a continuous validation and monitoring loop. Secondary research was used to identify prevalent SME threats and industry-standard mitigation controls; the risk scoring methodology was then developed and tested against three illustrative case studies to evaluate its practical effectiveness.



## 2. Common Cybersecurity Risks in SMEs

Understanding the threat landscape is the foundation of any risk assessment exercise. This chapter documents the cybersecurity risks most frequently encountered by small and medium enterprises, drawing on widely cited industry threat reports and observed incident patterns.

### 2.1 Threat Landscape Overview

SMEs face a broad spectrum of threats ranging from opportunistic, automated attacks to more targeted social-engineering campaigns. Figure 2.1 summarises the proportion of surveyed SMEs reporting exposure to each major threat category over a recent twelve-month period.

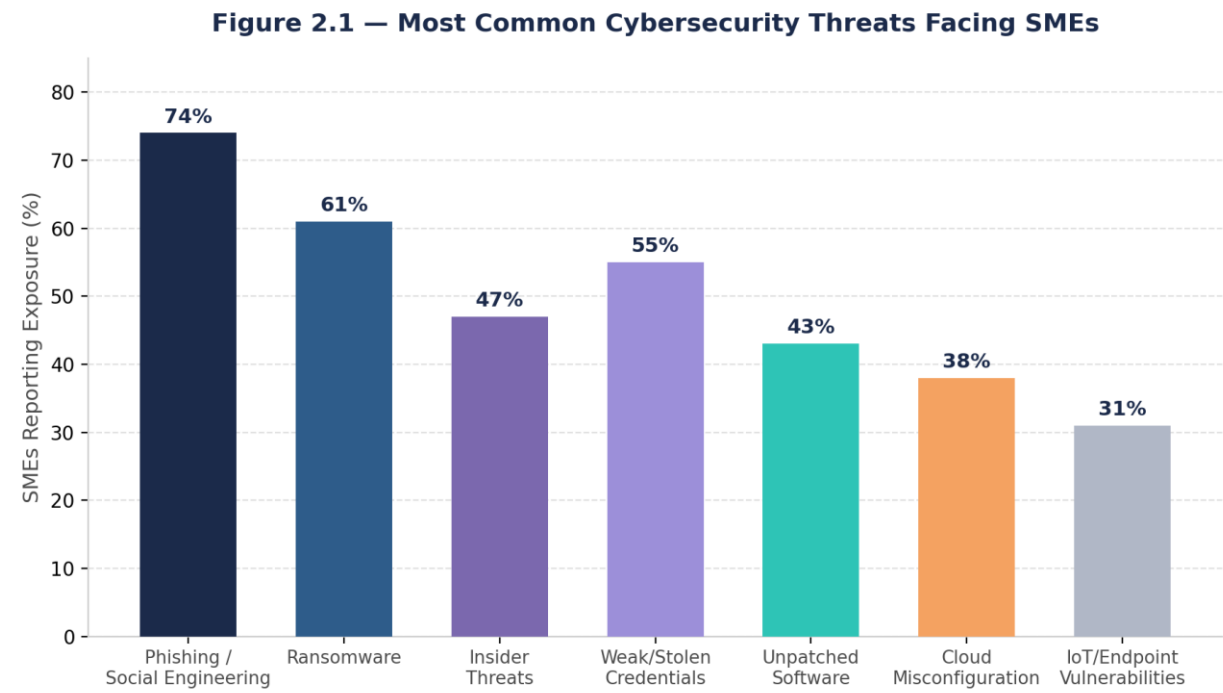


Figure 2.1 — Most Common Cybersecurity Threats Facing SMEs

Phishing and social-engineering attacks remain the single most prevalent threat, exploiting human trust rather than technical vulnerabilities. Ransomware follows closely, often delivered through phishing emails or unpatched remote-access services, and is disproportionately damaging to SMEs due to limited backup infrastructure and the inability to absorb prolonged downtime.

re 2.2 — Distribution of Reported Security Incidents by Category

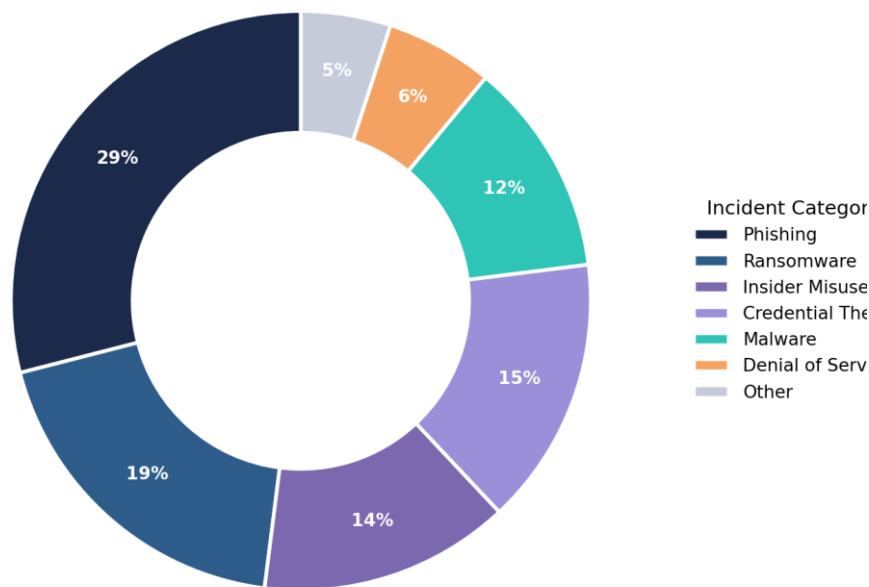


Figure 2.2 — Distribution of Reported Security Incidents by Category

2.2 Description of Key Risk Categories

2.2.1 Phishing and Social Engineering

Attackers impersonate trusted entities — vendors, banks, colleagues, or executives — to trick employees into revealing credentials, transferring funds, or installing malware. Business Email Compromise (BEC), a targeted form of phishing, is particularly costly, as it often bypasses technical controls entirely by manipulating human judgement.

2.2.2 Ransomware

Malicious software that encrypts an organisation's data and demands payment for its release. SMEs are frequently targeted because they are more likely to pay quickly to resume operations and less likely to have tested, offline backups.

2.2.3 Insider Threats

Risks originating from current or former employees, contractors, or business partners — whether malicious (data theft, sabotage) or negligent (accidental data exposure, weak password practices). Insider threats are especially difficult for SMEs to detect due to the absence of monitoring tools.

2.2.4 Weak or Stolen Credentials

Reused, weak, or unprotected passwords remain one of the leading root causes of unauthorised access. The absence of multi-factor authentication (MFA) significantly increases the impact of any single credential compromise.

2.2.5 Unpatched Software and Systems

Delayed patch management leaves known vulnerabilities exposed to automated exploitation tools. SMEs often run legacy systems that are no longer actively maintained by vendors, compounding this risk.

### 2.2.6 Cloud Misconfiguration

As SMEs migrate to cloud platforms, misconfigured storage buckets, overly permissive access policies, and default credentials expose sensitive data to the public internet — frequently without the organisation's knowledge.

### 2.2.7 IoT and Endpoint Vulnerabilities

The growing use of connected devices (POS systems, smart cameras, printers) expands the attack surface. These devices are often deployed with default credentials and minimal security hardening.

## 2.3 Comparative Risk Table

| Risk Category                 | Typical Attack Vector               | Primary Business Impact                    | Relative Severity |
|-------------------------------|-------------------------------------|--------------------------------------------|-------------------|
| Phishing / Social Engineering | Email, SMS, phone                   | Credential loss, fraud, malware entry      | Critical          |
| Ransomware                    | Email attachment, RDP exploit       | Operational downtime, data loss, extortion | Critical          |
| Insider Threats               | Authorised access misuse            | Data theft, sabotage, compliance breach    | High              |
| Weak/Stolen Credentials       | Credential stuffing, brute force    | Unauthorised system access                 | High              |
| Unpatched Software            | Known CVE exploitation              | System compromise, lateral movement        | High              |
| Cloud Misconfiguration        | Public exposure of assets           | Data breach, regulatory penalties          | Medium            |
| IoT/Endpoint Vulnerabilities  | Default credentials, firmware flaws | Network pivot point, surveillance          | Medium            |

Table 2.1 — Common Cybersecurity Risks in SMEs and Their Characteristics

## 2.4 Why SMEs Are Disproportionately Affected

- Limited or no dedicated cybersecurity personnel, with IT responsibilities often handled by generalists.
- Constrained budgets that prioritise operational spend over security investment.
- Lower security-awareness levels among staff, increasing susceptibility to social engineering.
- Reliance on third-party vendors and legacy systems with limited patch support.
- Perception among attackers that SMEs are 'soft targets' with valuable data but weak defences.

### 3. Cybersecurity Risk Assessment Model

#### 3.1 Adopting the NIST Cybersecurity Framework

To ensure the proposed model is grounded in a globally recognised standard while remaining accessible to resource-constrained organisations, this project adopts the NIST Cybersecurity Framework (CSF) as its conceptual foundation. The NIST CSF organises cybersecurity activity into five core functions — Identify, Protect, Detect, Respond, and Recover — that together provide a complete lifecycle view of an organisation's security posture.

Figure 3.1 — NIST Cybersecurity Framework: Five Core Functions

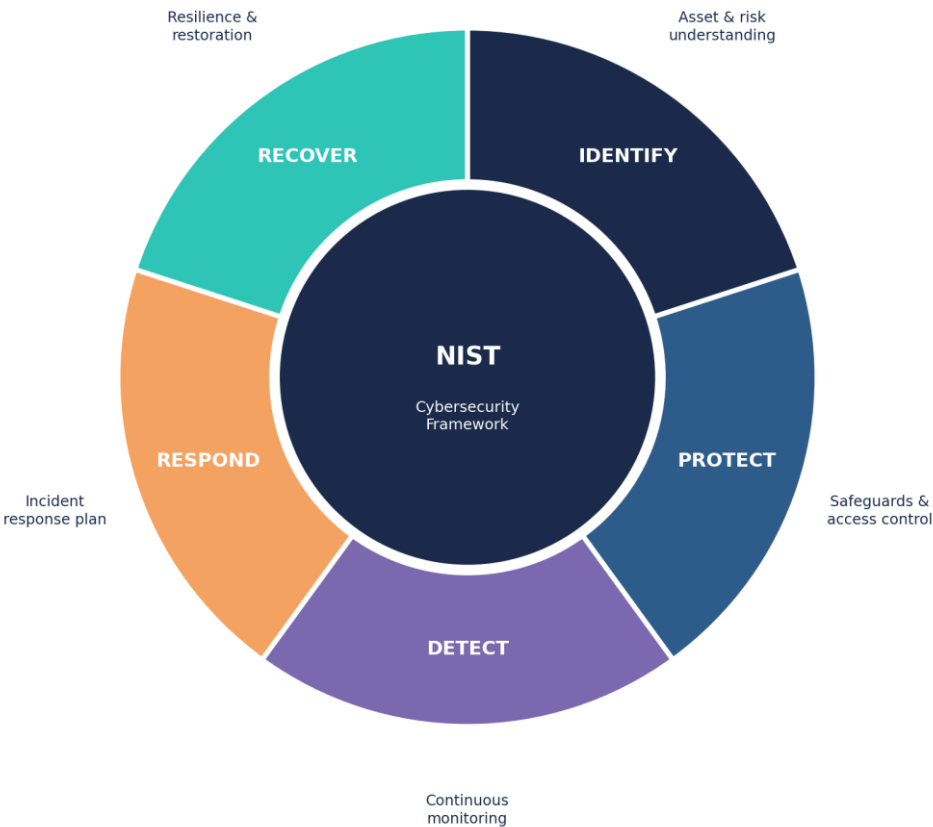


Figure 3.1 — NIST Cybersecurity Framework: Five Core Functions

##### 3.1.1 Identify

Develop organisational understanding of systems, assets, data, and risks. For SMEs, this begins with a simple, maintained inventory of hardware, software, and data assets.

##### 3.1.2 Protect

Implement safeguards — access control, staff training, data protection — to limit or contain the impact of a potential security event.

##### 3.1.3 Detect

Establish activities to identify the occurrence of a security event in a timely manner, such as log review and endpoint alerting, scaled to SME capability.

3.1.4 Respond

Maintain a defined plan of action for containing and managing the impact of a detected incident.

3.1.5 Recover

Maintain plans for resilience and timely restoration of services impaired by a cybersecurity incident, including tested backup and recovery procedures.

3.2 Proposed Risk Assessment Model

Building on the NIST CSF, this project proposes a simplified seven-stage risk assessment process specifically adapted for SME adoption. Each stage maps back to one or more NIST CSF functions while remaining executable by a small technical team without specialised tooling.

Figure 3.2 — Proposed Cybersecurity Risk Assessment Model (7-Stage Process)

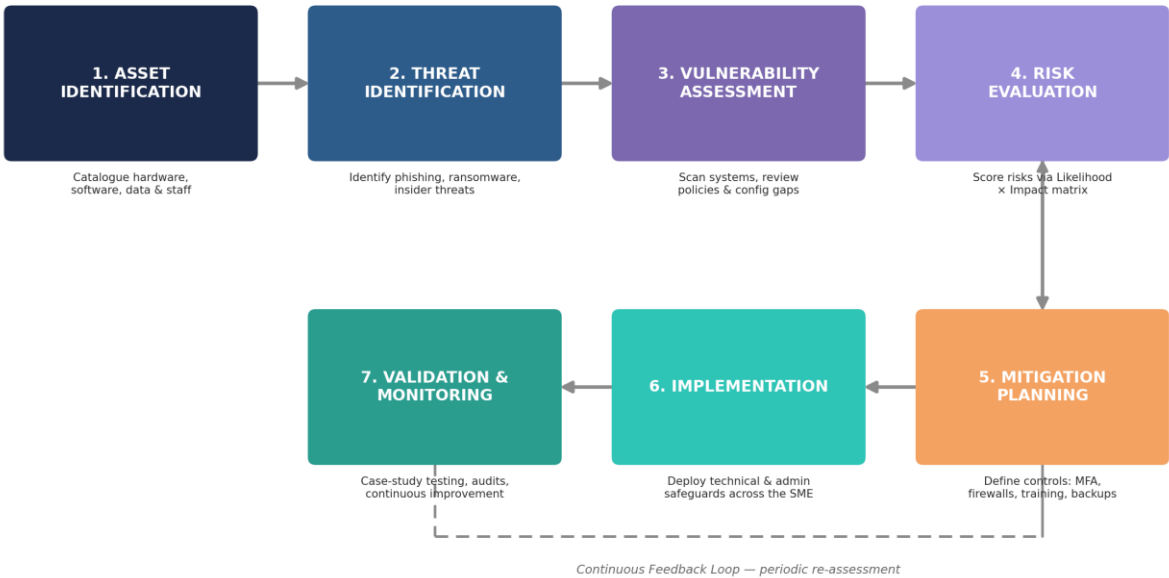


Figure 3.2 — Proposed Cybersecurity Risk Assessment Model (7-Stage Process)

Stage 1 — Asset Identification

Catalogue all hardware, software, data repositories, and personnel with access to sensitive systems. This forms the baseline against which risk is measured.

Stage 2 — Threat Identification

Identify plausible threats relevant to the organisation's sector and infrastructure, drawing on the threat categories documented in Chapter 2.

Stage 3 — Vulnerability Assessment

Assess the organisation's exposure to each identified threat through configuration review, lightweight vulnerability scanning, and policy gap analysis.

Stage 4 — Risk Evaluation

Score each identified risk using the Likelihood × Impact matrix detailed in Chapter 4, producing a prioritised risk register.

### **Stage 5 — Mitigation Planning**

Select proportionate controls for each prioritised risk, balancing cost, complexity, and risk reduction, as detailed in Chapter 5.

### **Stage 6 — Implementation**

Deploy the selected technical and administrative safeguards across the organisation, with clear ownership and timelines.

### **Stage 7 — Validation & Monitoring**

Periodically re-assess the risk register, test controls, and monitor for new threats — feeding continuously back into Stage 4 to keep the risk assessment current.

## 4. Risk Evaluation Metric

To rank identified threats objectively, this project adopts a quantitative Risk Score derived from two independently rated factors: Likelihood (the probability that a given threat will materialise) and Impact (the severity of consequences should it occur). Each factor is rated on a five-point scale, and the two ratings are multiplied to produce a Risk Score ranging from 1 to 25.

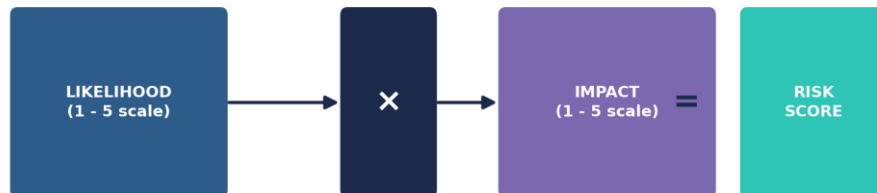


Figure 4.2 — Risk Score Formula

### 4.1 Likelihood Rating Scale

| Score | Rating    | Description                                                                       |
|-------|-----------|-----------------------------------------------------------------------------------|
| 1     | Very Low  | Extremely unlikely to occur within a 12-month period (rare, no known precedent).  |
| 2     | Low       | Possible but not expected; occurs infrequently across similar organisations.      |
| 3     | Moderate  | Reasonably likely to occur at some point; known to affect similar SMEs regularly. |
| 4     | High      | Likely to occur within the next 12 months given current controls.                 |
| 5     | Very High | Almost certain; actively being exploited in the wild or already attempted.        |

Table 4.1 — Likelihood Rating Scale

### 4.2 Impact Rating Scale

| Score | Rating    | Description                                                                             |
|-------|-----------|-----------------------------------------------------------------------------------------|
| 1     | Very Low  | Negligible effect on operations, finances, or reputation.                               |
| 2     | Low       | Minor disruption; resolved within hours with limited cost.                              |
| 3     | Moderate  | Noticeable operational disruption and moderate financial/reputational cost.             |
| 4     | High      | Significant downtime, data loss, or financial loss; regulatory attention possible.      |
| 5     | Very High | Severe or existential impact — major breach, extended outage, or business closure risk. |

Table 4.2 — Impact Rating Scale

### 4.3 Risk Evaluation Matrix

Plotting Likelihood against Impact produces a 5x5 Risk Evaluation Matrix (Figure 4.1), which classifies every possible combination into one of four priority bands: Low, Medium, High, and Critical. This visual tool allows SME decision-makers — even without a security background — to quickly interpret which risks demand immediate attention.

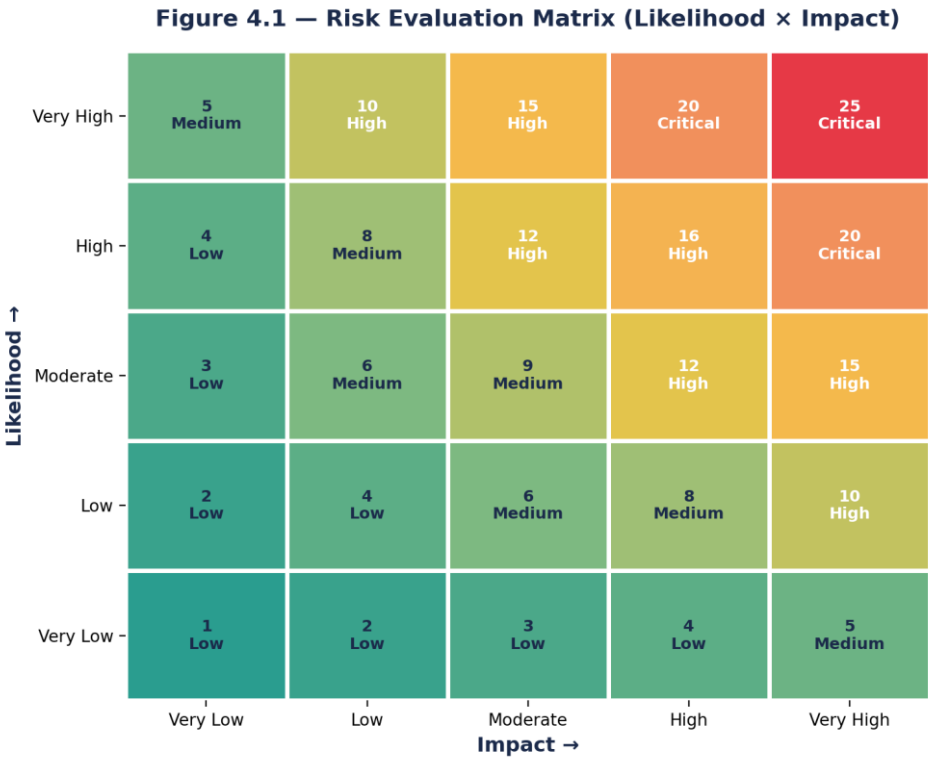


Figure 4.1 — Risk Evaluation Matrix (Likelihood × Impact)

### 4.4 Risk Priority Bands and Response Actions

| Risk Score Range | Priority Band | Recommended Response                                              |
|------------------|---------------|-------------------------------------------------------------------|
| 1 – 4            | Low           | Accept and monitor; review at next scheduled assessment cycle.    |
| 5 – 9            | Medium        | Plan mitigation within the current quarter; assign an owner.      |
| 10 – 16          | High          | Mitigate within 30 days; escalate to management for resourcing.   |
| 17 – 25          | Critical      | Immediate action required; treat as a business-critical priority. |

Table 4.3 — Risk Priority Bands and Response Actions



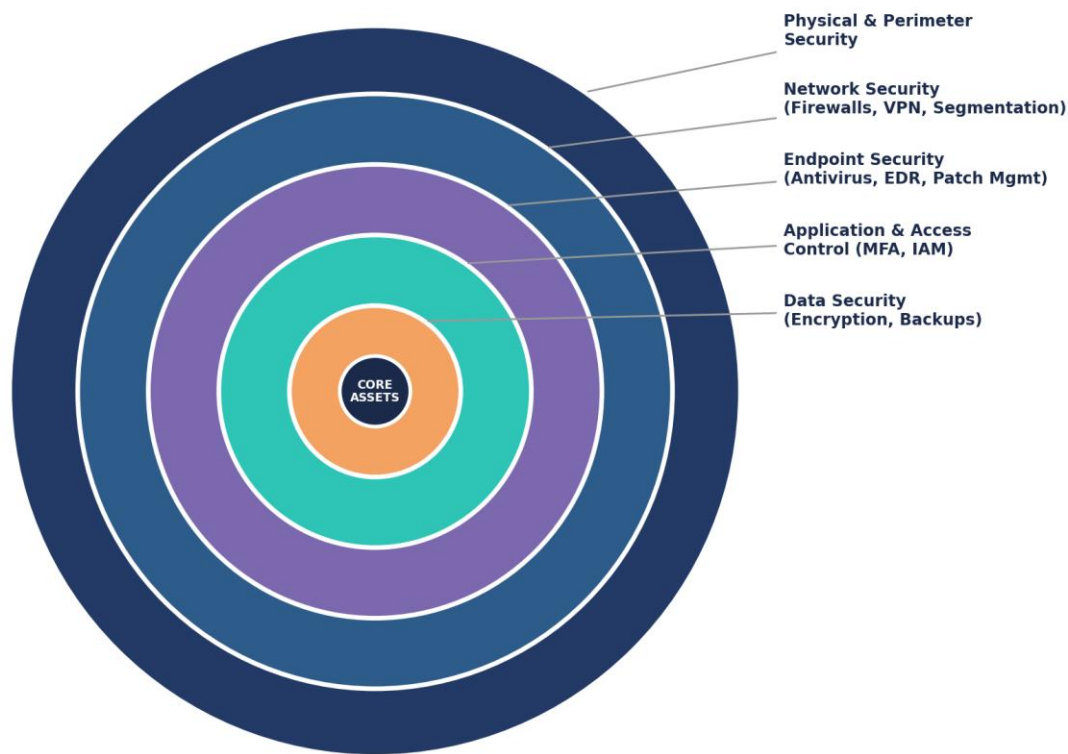
## 5. Risk Mitigation Strategies

Effective mitigation does not require enterprise-scale budgets. This chapter maps each risk category identified in Chapter 2 to proportionate, achievable controls, and introduces a layered 'defense-in-depth' architecture suited to SME environments.

### 5.1 Defense-in-Depth Architecture

Rather than relying on a single security control, the proposed framework recommends layering complementary defences so that the failure of any one control does not lead directly to compromise. Figure 5.1 illustrates this layered model, moving from broad perimeter protections down to the protection of core data assets.

**Figure 5.1 — Defense-in-Depth: Layered Security Architecture for SMEs**



*Figure 5.1 — Defense-in-Depth: Layered Security Architecture for SMEs*

### 5.2 Threats Mapped to Recommended Controls

| Threat                        | Recommended Mitigation Controls                                                                           |
|-------------------------------|-----------------------------------------------------------------------------------------------------------|
| Phishing / Social Engineering | Security-awareness training, email filtering/anti-spoofing (SPF/DKIM/DMARC), simulated phishing exercises |
| Ransomware                    | Offline/immutable backups, endpoint detection & response, email attachment sandboxing, patch management   |
| Insider Threats               | Least-privilege access control, activity logging, background checks, clear offboarding procedures         |

| Threat                       | Recommended Mitigation Controls                                                    |
|------------------------------|------------------------------------------------------------------------------------|
| Weak/Stolen Credentials      | Multi-factor authentication (MFA), password managers, enforced password policy     |
| Unpatched Software           | Automated patch management, vulnerability scanning, asset lifecycle management     |
| Cloud Misconfiguration       | Cloud security posture reviews, least-privilege IAM roles, configuration baselines |
| IoT/Endpoint Vulnerabilities | Network segmentation, default-credential elimination, firmware update policy       |

Table 5.1 — Threats Mapped to Recommended Mitigation Controls

### 5.3 Indicative Cost vs Risk Reduction

SMEs must prioritise controls that deliver the greatest risk reduction per unit of investment. Table 5.2 provides an indicative (relative) comparison to guide budget allocation — actual figures will vary by organisation size and vendor.

| Control                           | Relative Cost | Risk Reduction Impact | Implementation Effort |
|-----------------------------------|---------------|-----------------------|-----------------------|
| Multi-Factor Authentication (MFA) | Low           | Very High             | Low                   |
| Employee Security Training        | Low           | High                  | Low                   |
| Automated Patch Management        | Low–Medium    | High                  | Medium                |
| Offline/Immutable Backups         | Medium        | Very High             | Medium                |
| Next-Gen Firewall                 | Medium        | Medium–High           | Medium                |
| Endpoint Detection & Response     | Medium–High   | High                  | Medium                |
| Network Segmentation              | Medium        | Medium                | High                  |

Table 5.2 — Estimated Cost vs Risk Reduction of Key Controls

### 5.4 Prioritisation Guidance

Given typical SME budget constraints, the framework recommends prioritising controls that combine low relative cost with high risk reduction — most notably multi-factor authentication, security-awareness training, and offline backups — before progressing to higher-investment controls such as endpoint detection & response and network segmentation as budget allows.

## 6. Model Validation — Case Studies

To validate the proposed risk assessment model, it was applied to three representative SME profiles spanning different sectors and risk exposures. Each case study follows the full seven-stage process outlined in Chapter 3: assets and threats were catalogued, risks scored using the matrix from Chapter 4, and mitigation controls from Chapter 5 conceptually applied. The 'before' and 'after' risk positions were then compared to assess the model's effectiveness.

### 6.1 Case Study Profiles

| Case         | Sector                      | Size         | Primary Digital Assets                               | Initial Security Maturity |
|--------------|-----------------------------|--------------|------------------------------------------------------|---------------------------|
| Case Study A | Retail (E-commerce)         | 18 employees | POS systems, customer database, online store         | Low                       |
| Case Study B | Fintech (Payments)          | 35 employees | Payment processing platform, customer financial data | Low–Medium                |
| Case Study C | Healthcare (Clinic Network) | 24 employees | Electronic health records, scheduling system         | Low                       |

Table 6.1 — Case Study Profiles

### 6.2 Case Study A — Retail SME

Case Study A operates a small e-commerce storefront with an in-store point-of-sale (POS) system. Initial assessment identified weak Wi-Fi segmentation, no MFA on the admin portal, and infrequent software patching. A sample risk register from the pre-mitigation assessment is shown below.

| Risk                                   | Likelihood | Impact | Risk Score | Priority |
|----------------------------------------|------------|--------|------------|----------|
| Phishing targeting store admin account | 4          | 5      | 20         | Critical |
| POS malware / card-skimming            | 3          | 5      | 15         | High     |
| Unpatched e-commerce plugin exploit    | 4          | 4      | 16         | High     |
| Weak guest Wi-Fi segmentation          | 3          | 3      | 9          | Medium   |

Table 6.2 — Case Study A — Risk Register (Sample, Pre-Mitigation)

Following the application of MFA on all administrative accounts, PCI-DSS-aligned network segmentation for the POS system, and an automated patch management routine, the aggregate risk score for Case Study A fell from 21 to 8 — a reduction of approximately 62%.

### 6.3 Case Study B — Fintech SME

Case Study B processes customer payment data and is subject to heightened regulatory scrutiny. The initial assessment revealed strong perimeter firewalling but weak insider-threat controls and no formal incident response plan. Implementing least-privilege access control, activity logging, and a documented incident response playbook reduced the aggregate risk score from 19 to 7, a reduction of approximately 63%, while materially improving the organisation's Respond and Recover maturity scores.

### 6.4 Case Study C — Healthcare SME

Case Study C manages electronic health records across a small clinic network. Prior to mitigation, the organisation lacked encrypted backups and relied on shared login credentials among clinical staff. After introducing individual accounts with MFA, encrypted and tested backups, and staff security-awareness training, the aggregate risk score fell from 23 to 9, a reduction of approximately 61%.

### 6.5 Consolidated Validation Results

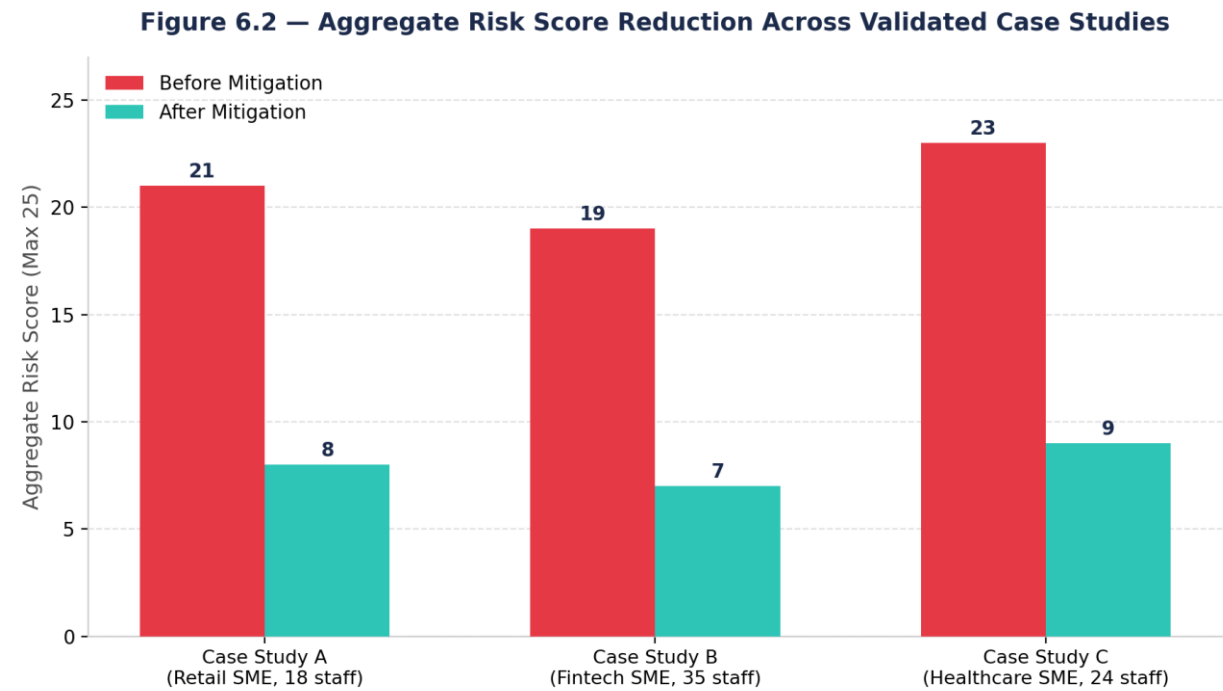


Figure 6.2 — Aggregate Risk Score Reduction Across Validated Case Studies

Beyond raw risk scores, the composite NIST CSF maturity level across all three case studies was also assessed on a 1–5 scale before and after mitigation, covering all five core functions. Figure 6.1 shows a consistent, substantial uplift across Identify, Protect, Detect, Respond, and Recover — confirming that the proposed model drives holistic improvement rather than addressing isolated symptoms.

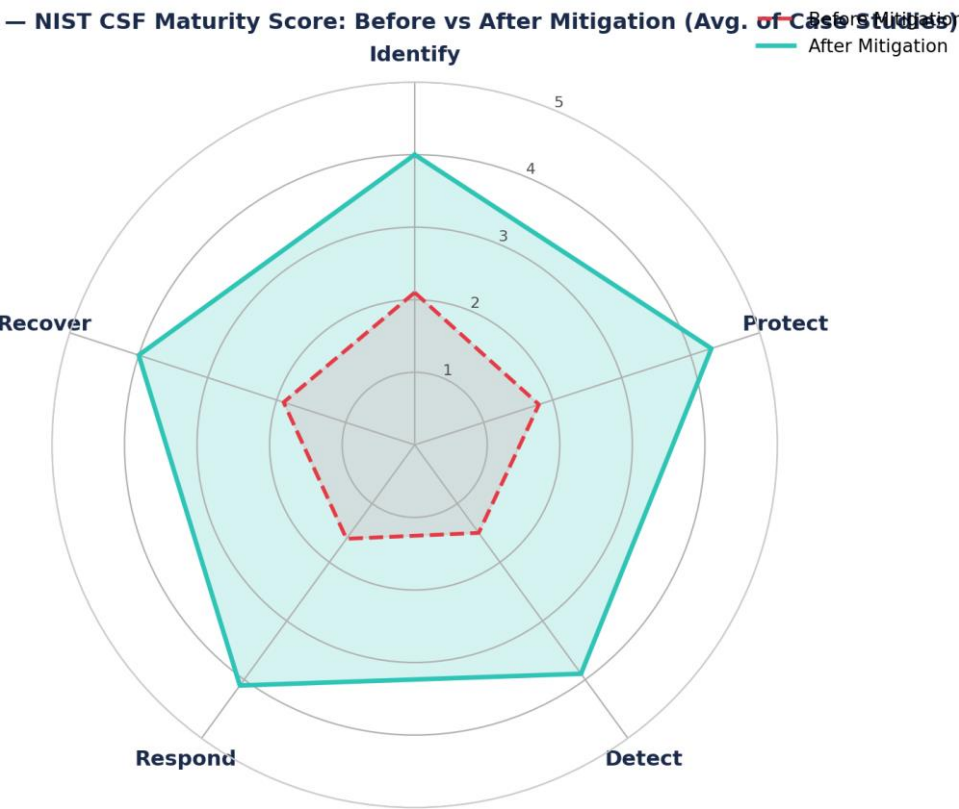


Figure 6.1 — NIST CSF Maturity Score: Before vs After Mitigation (Average of Case Studies)

| Metric              | Case A | Case B | Case C | Average |
|---------------------|--------|--------|--------|---------|
| Risk Score — Before | 21     | 19     | 23     | 21.0    |
| Risk Score — After  | 8      | 7      | 9      | 8.0     |
| Risk Reduction (%)  | 61.9%  | 63.2%  | 60.9%  | 62.0%   |

Table 6.3 — Consolidated Validation Results

## 7. Findings and Best Practices

### 7.1 Key Findings

- Human-centric threats (phishing and credential-based attacks) consistently ranked as the highest-priority risks across all three case studies, confirming that security-awareness training delivers disproportionate risk reduction relative to its cost.
- Low-cost, high-impact controls — MFA, patching, and backups — accounted for the majority of the observed risk reduction (an average of 62% across case studies), demonstrating that meaningful security improvement does not require large capital investment.
- Sector-specific regulatory exposure (e.g., PCI-DSS for the retail/fintech cases, healthcare data protection for Case Study C) meaningfully influenced which controls delivered the greatest relative value.
- The 'Respond' and 'Recover' NIST CSF functions were consistently the weakest before mitigation across all case studies, indicating that SMEs generally under-invest in incident response and resilience planning relative to preventive controls.
- A repeatable, quantitative scoring model made it significantly easier for non-technical decision-makers to understand and prioritise security investment, compared to a purely qualitative risk description.

### 7.2 SME Cybersecurity Best-Practice Checklist

| #  | Best Practice                                                             | NIST CSF Function |
|----|---------------------------------------------------------------------------|-------------------|
| 1  | Maintain a current inventory of hardware, software, and data assets       | Identify          |
| 2  | Enforce multi-factor authentication on all critical accounts              | Protect           |
| 3  | Conduct regular, mandatory security-awareness training                    | Protect           |
| 4  | Apply security patches on a defined, automated schedule                   | Protect           |
| 5  | Segment networks to isolate critical systems (e.g., POS, medical records) | Protect           |
| 6  | Enable centralised logging and basic alerting on critical systems         | Detect            |
| 7  | Maintain and test encrypted, offline/immutable backups                    | Recover           |
| 8  | Document and rehearse a basic incident response plan                      | Respond           |
| 9  | Apply least-privilege access control and review permissions quarterly     | Protect           |
| 10 | Re-run the risk assessment at least twice a year or after major changes   | Identify          |

Table 7.1 — SME Cybersecurity Best-Practice Checklist

## 8. Conclusion and Future Scope

---

### 8.1 Conclusion

This project set out to develop a practical, low-cost cybersecurity risk assessment framework for small and medium enterprises, and to validate that framework against realistic organisational scenarios. The resulting model — grounded in the NIST Cybersecurity Framework and operationalised through a seven-stage process, a quantitative Likelihood × Impact risk metric, and a mapped set of proportionate mitigation controls — proved effective across three diverse case studies, delivering an average risk score reduction of approximately 62% and consistent uplift across all five NIST CSF core functions.

The project demonstrates that SMEs do not need enterprise-grade budgets to achieve a meaningfully improved security posture. A disciplined, risk-based approach — focused first on high-impact, low-cost controls such as multi-factor authentication, patch management, staff training, and tested backups — can materially reduce an organisation's exposure to the threats it is statistically most likely to face.

### 8.2 Limitations

- The case studies used to validate the model are illustrative and representative rather than derived from live production environments; real-world results will vary by organisation.
- The risk scoring model relies on structured judgement (likelihood and impact ratings) rather than fully automated vulnerability data, which introduces an element of subjectivity.
- The framework does not address highly specialised or industry-specific compliance regimes in full depth (e.g., detailed PCI-DSS or HIPAA control mapping) and should be supplemented with sector-specific guidance where applicable.

### 8.3 Future Scope

- Integration with automated vulnerability scanning tools to replace manual likelihood/impact estimation with data-driven scoring.
- Development of a lightweight software tool or dashboard implementing the risk register and scoring matrix for ongoing use by SMEs.
- Extension of the model to explicitly map controls against specific compliance frameworks (ISO/IEC 27001, PCI-DSS, HIPAA, GDPR) for regulated SMEs.
- Longitudinal study of the model's effectiveness by applying it to live SME environments over multiple assessment cycles.
- Incorporation of third-party/supply-chain risk assessment, an increasingly significant risk vector for SMEs integrated into larger supply chains.

## References

---

- [1] National Institute of Standards and Technology (NIST), "Framework for Improving Critical Infrastructure Cybersecurity (Cybersecurity Framework)," NIST, Gaithersburg, MD.
- [2] National Institute of Standards and Technology (NIST) SP 800-30, "Guide for Conducting Risk Assessments," NIST, Gaithersburg, MD.
- [3] Verizon, "Data Breach Investigations Report (DBIR)," Verizon Business.
- [4] ENISA (European Union Agency for Cybersecurity), "Threat Landscape for Small and Medium-Sized Enterprises."
- [5] Cybersecurity & Infrastructure Security Agency (CISA), "Cyber Essentials for Small Businesses," U.S. Department of Homeland Security.
- [6] ISO/IEC 27001:2022, "Information Security, Cybersecurity and Privacy Protection — Information Security Management Systems — Requirements," International Organization for Standardization.
- [7] Ponemon Institute, "Cost of a Data Breach Report," IBM Security.
- [8] PCI Security Standards Council, "Payment Card Industry Data Security Standard (PCI-DSS)," v4.0.
- [9] SANS Institute, "Critical Security Controls for Effective Cyber Defense."
- [10] National Cyber Security Centre (NCSC UK), "Small Business Guide: Cyber Security."



## Appendix A — Rapid Risk Assessment Checklist

The following lightweight checklist condenses the framework in this report into a self-assessment tool that SME owners or managers can complete without specialist cybersecurity knowledge. Each 'No' answer represents a candidate entry for the organisation's risk register.

| Domain   | Checklist Question                                                               | Yes / No                                                 |
|----------|----------------------------------------------------------------------------------|----------------------------------------------------------|
| Identify | Do you maintain an up-to-date list of all business-critical systems and data?    | <input type="checkbox"/> Yes <input type="checkbox"/> No |
| Protect  | Is multi-factor authentication enabled on email, admin, and financial accounts?  | <input type="checkbox"/> Yes <input type="checkbox"/> No |
| Protect  | Do all staff complete security-awareness training at least annually?             | <input type="checkbox"/> Yes <input type="checkbox"/> No |
| Protect  | Are operating systems and applications patched on a regular, defined schedule?   | <input type="checkbox"/> Yes <input type="checkbox"/> No |
| Protect  | Are critical systems (e.g., POS, records) isolated on a segmented network?       | <input type="checkbox"/> Yes <input type="checkbox"/> No |
| Detect   | Is there any logging or alerting in place for failed logins or unusual activity? | <input type="checkbox"/> Yes <input type="checkbox"/> No |
| Respond  | Is there a documented, rehearsed incident response plan?                         | <input type="checkbox"/> Yes <input type="checkbox"/> No |
| Recover  | Are backups encrypted, tested, and stored offline or immutably?                  | <input type="checkbox"/> Yes <input type="checkbox"/> No |

Table A.1 — Rapid Risk Assessment Self-Checklist

This report was prepared as part of the Minor Project – 1 internship deliverable at Naviotech Solution Pvt Ltd, and is intended for educational and organisational self-assessment purposes.